AWS Certified DevOps Engineer – Professional（DOP-C02）　タスク 6.1　#20

IAM とマルチアカウントのアクセス

ロール・一時的な認証情報・インスタンスプロファイル・サービスにリンクされたロール・iam:PassRole、ポリシーの評価・クロスアカウント・信頼ポリシー・外部 ID、アクセス許可の境界・セッションポリシー・ABAC・MFA の条件・最終アクセス情報・IAM Access Analyzer、OIDC・SAML・IAM Roles Anywhere・実行ロール・EKS Pod Identity・IRSA・認証情報レポート・ローテーション・SCP

各ページの下に、根拠にした資料（AWS の DOP-C02 試験ガイド、IAM・EKS・Organizations・Secrets Manager の各ガイド、IAM Roles Anywhere〔英語版〕）を書いた。
『』の中はドキュメントの原文どおり

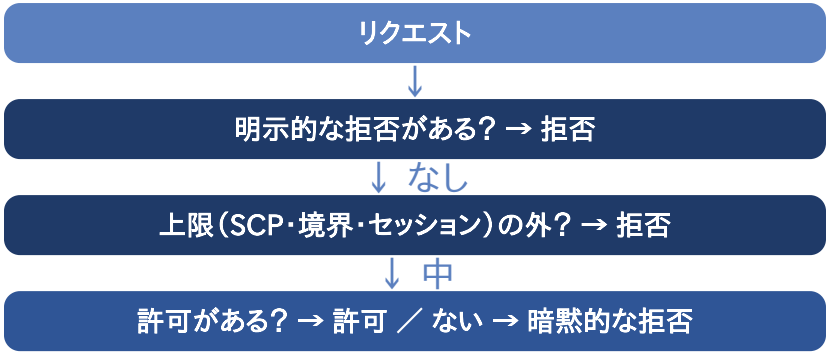
第1章

IAM のしくみとアカウントをまたぐアクセス

許可を与えるポリシーと、上限を決めるポリシー。

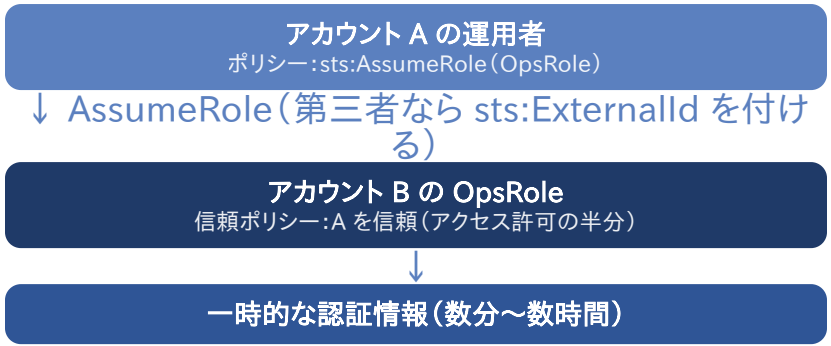
ポリシーの種類と評価

ポリシー	はたらき
アイデンティティベース	許可を与える（ユーザー・グループ・ロール）
リソースベース	許可を与える（S3・SQS・KMS…他アカウントも指定可）
SCP・RCP	上限（組織・OU・アカウント）
アクセス許可の境界	上限（ユーザー・ロール）
セッションポリシー	上限（そのセッション）



出典：ポリシーとアクセス許可『セッションポリシーでは、作成したセッションのアクセス許可が制限されますが、アクセス許可は付与されません。』／アイデンティティベースおよびリソースベースのポリシー／ポリシーの評価論理

ロールとアカウントをまたぐアクセス



用語	ポイント
インスタンスプロファイル	EC2 にロールを渡す入れ物
サービスにリンクされたロール	サービスが前もって決めた権限。編集しない
iam:PassRole	サービスにロールを渡す権限。ロールの ARN で絞る
外部 ID	混乱した代理を防ぐ

出典：IAM ロール『信頼ポリシーは、信頼するアカウントのロールにアタッチされ、アクセス許可の半分です。』／第三者が所有するアカウントへのアクセス／インスタンスプロファイル／サービスにリンクされたロール／ロールを渡す

第2章

最小権限の設計と見直し

上限で守り、タグで広げ、使っていないものを削る。

上限・属性・条件

アクセス許可の境界
アイデンティティのポリシー ∩ 境界 だけ使える。開発者にロール作成を任せるとき iam:PermissionsBoundary で強制

例：ポリシー s3:*・ec2:*、境界 s3:* → S3 だけ

セッションポリシー
ロールは変えずに、その実行だけ絞る

条件キー	使い道
aws:ResourceTag と aws:PrincipalTag	ABAC：タグが一致したら許可
aws:MultiFactorAuthPresent	MFA の後だけ許可
aws:RequestedRegion	リージョンを絞る（SCP で）
aws:PrincipalOrgID	組織の中だけ

RBAC は役割ごとにポリシー → 増えるたびに直す。ABAC は増えても直さない。

出典：アクセス許可境界『エンティティのアクセス許可の境界により、エンティティは、アイデンティティベースのポリシーとそのアクセス許可の境界の両方で許可されているアクションのみを実行できます。』／ABAC／MFA を使用した安全な API アクセス

見直す道具

道具	わかること	使い道
最終アクセス情報	各サービスを最後に使った日	使っていないサービスを外す
Access Analyzer：外部アクセス	組織の外と共有されたリソース	公開の S3・外部に開いたロールを見つける
Access Analyzer：未使用のアクセス	使われていないロール・キー・権限	組織全体を続けて見張る
Access Analyzer：ポリシー生成	CloudTrail から実際に使ったアクション	最小のポリシーのひな形
認証情報レポート	全 IAM ユーザーのパスワード・キー・MFA	監査

出典：最終アクセス情報『IAM は、未使用のアクセス許可を特定して削除できるようにするために、最終アクセス情報を提供します。』／Access Analyzer の使用・検出結果・ポリシーの生成／認証情報レポート

第3章

人とマシンの認証情報

長期のアクセスキーを置かない。

だれが、どうやって入るか

だれが	しくみ	ポイント
社員	IAM Identity Center ／ SAML フェデレーション → ロール	IAM ユーザーを作らない
GitHub Actions などの CI	IAM の OIDC プロバイダー → AssumeRoleWithWebIdentity	信頼ポリシーでリポジトリ・ブランチを絞る
EC2・Lambda・ECS	インスタンスプロファイル・実行ロール・タスクロール	SDK が一時的な認証情報を自動で使う
EKS の Pod	Pod Identity（エージェント）／IRSA（クラスターの OIDC）	ノードのロールに全部付けない
オンプレミス	IAM Roles Anywhere（X.509 証明書・トラストアンカー）	長期のキーをやめる
アプリの秘密の値	Secrets Manager の自動ローテーション	DB パスワード・外部 API キー

出典：セキュリティのベストプラクティス『人間のユーザーが AWS にアクセスする際は、一時的な認証情報の使用が必要です。』／OIDC ID プロバイダー／SAML 2.0 フェデレーション／IAM Roles Anywhere（英語版）／EKS Pod Identity・IRSA／Secrets Manager のローテーション

本番での問われ方

ねらい	見るところ
評価	明示的な拒否が勝つ、SCP・境界・セッションポリシーは許可を与えない
アカウントをまたぐ	信頼ポリシー＋sts:AssumeRole の両方、リソースベースのポリシー、外部 ID
最小権限	境界で委任、ABAC、MFA の条件、PassRole を絞る
見直し	最終アクセス情報、Access Analyzer（外部・未使用・ポリシー生成）、認証情報レポート
認証情報	フェデレーション、CI は OIDC、Roles Anywhere、Pod Identity・IRSA、Secrets Manager のローテーション

出典：AWS Certified DevOps Engineer - Professional (DOP-C02) 試験ガイド タスク 6.1